

Enterprise SaaS Master Services Agreement

VectorCloud Systems Inc. and Northstar Retail Holdings – analytics, workflow automation, CRM, and identity integrations

Synthetic legal-style test document for agent evaluation. Not legal advice. No real parties.

Parties And Scope

This Master Services Agreement is entered into between VectorCloud Systems Inc., a Delaware corporation, and Northstar Retail Holdings, a regional retail and logistics group. The services include hosted workflow automation, supplier analytics, marketing operations reporting, case management, and configurable AI-assisted summaries.

The platform will integrate with Microsoft Entra ID, Microsoft 365, Salesforce CRM, ServiceNow vendor risk, Snowflake, SFTP drops, and a customer-managed SIEM. Provider will not receive direct payment card numbers but may process transaction metadata, customer identifiers, employee contact data, purchase order details, support tickets, and supplier due diligence records.

Subscription Services

- Provider shall deliver multi-tenant SaaS access with logical tenant isolation, regional hosting in Ireland and the United States, and configurable data retention periods.
- Provider may use AI-assisted case summaries only inside the customer tenant. Customer content shall not be used to train foundation models, improve shared models, or create external benchmarks.
- Provider shall support SAML 2.0 SSO, SCIM provisioning, IP allowlisting, API keys with rotation, webhook signing, and role-based access control.

Commercial Terms

The initial term is 36 months. Fees are based on named users, API events, and retained evidence volume. Production use may not start until security onboarding, privacy review, and integration approval are completed.

Provider shall not materially change subprocessors, hosting regions, retention settings, or AI data-use terms without 60 days prior notice and customer opportunity to object.

Data Protection And Privacy

- A signed Data Processing Addendum is incorporated by reference. Provider is a processor for customer personal data and a controller only for billing, account, and fraud-prevention records.
- Personal data categories include business contact data, customer loyalty identifiers, employee names, approver emails, device identifiers, ticket narratives, and supplier contacts.
- Provider shall delete or return customer data within 45 days after termination, except for immutable security logs retained for compliance and dispute defense.
- Provider shall maintain subprocessor due diligence, cross-border transfer safeguards, and documented retention schedules.

Security Controls

- Provider shall maintain ISO 27001 or SOC 2 Type II controls, annual penetration testing, vulnerability remediation tracking, endpoint hardening, and centralized logging.
- Provider shall enforce least privilege, MFA, named accounts, privileged access review, break-glass controls, and quarterly access recertification.
- Provider shall encrypt data in transit using TLS 1.2 or higher and encrypt data at rest using a recognized key management service.

- Provider shall notify Customer of confirmed security incidents without undue delay and no later than 48 hours after confirmation.

Audit, Evidence, And Records

- Provider shall preserve audit logs, integration logs, access approvals, configuration changes, incident tickets, and data export records for at least 18 months.
- Customer may request security attestations, remediation summaries, subprocessor lists, continuity evidence, and access reports during onboarding and annual review.

Continuity And Exit

- Provider shall maintain business continuity and disaster recovery plans with annual tabletop testing and target recovery time objective of 12 hours for the production control plane.
- Provider shall provide reasonable exit assistance for 90 days, including export of audit logs, evidence attachments, configuration metadata, and integration mappings in CSV or JSON format.

Approval Gate

This agreement is not sufficient for go-live without a completed access approval record, DPA confirmation, security assurance packet, and integration architecture review.

Reference Basis For Synthetic Fixture

This fixture is original synthetic text. It uses public legal, regulatory, security, cloud, export-control, and AI governance sources only as structural reference points. It is not legal advice and is not a copy of any source template.

Reference | GOV.UK Model Services Contract | Applied for: complex services structure, schedules, service levels, exit management, security, schedule patterns | <https://www.gov.uk/government/collections/model-services-contract>

Reference | ICO controller and processor contract guidance | Applied for: processor instructions, confidentiality, subprocessors, assistance, deletion, audit, breach support | <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/contracts-and-liabilities-between-controllers-and-processors-multi/>

Reference | European Commission controller-processor SCCs and transfer SCC overview | Applied for: SCC-style annexes, processing description, technical measures, transfer safeguards | https://commission.europa.eu/publications/standard-contractual-clauses-controller-and-processors-eueea_en

Reference | BIS Export Administration Regulations and advanced computing end-use controls | Applied for: classification, license analysis, end-use, end-user, restricted-party, re-export, transfer controls | <https://www.bis.gov/entity-list>

Reference | NIST SP 800-161 Rev. 1 Cybersecurity Supply Chain Risk Management | Applied for: supplier assurance, provenance, counterfeit/tamper controls, ongoing monitoring, acquisition evidence | <https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>

Reference | NIST SP 800-53 Rev. 5 security and privacy control families | Applied for: access control, audit, incident response, contingency planning, acquisition, privacy, supply-chain controls | <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

Reference | NIST AI Risk Management Framework | Applied for: AI governance, human oversight, testing, documentation, transparency, monitoring, risk management | <https://www.nist.gov/itl/ai-risk-management-framework>

Reference | Cloud Security Alliance Cloud Controls Matrix | Applied for: cloud shared responsibility, identity, logging, data security, resilience, vendor assurance domains | <https://cloudsecurityalliance.org/research/cloud-controls-matrix>

Schedule A - Commercial And Governance Terms

This schedule converts the business request into a production-ready contract package for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries. The parties acknowledge the primary regulated focus as privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk.

1. Definitions And Interpretation

For Enterprise SaaS, VectorCloud Systems Inc. shall define controlled terms, service boundary, covered affiliates, data classes, evidence artifacts, and approval gates. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for definitions and interpretation.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 01 | Area: Definitions And Interpretation | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

2. Order Of Precedence

For Enterprise SaaS, VectorCloud Systems Inc. shall resolve conflicts between the order form, schedules, security annex, DPA, support policies, and statements of work. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for order of precedence.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 02 | Area: Order Of Precedence | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

3. Statement Of Work Controls

For Enterprise SaaS, VectorCloud Systems Inc. shall require every work package to identify scope, owners, data, systems, locations, subcontractors, acceptance tests, and blockers. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for statement of work controls.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 03 | Area: Statement Of Work Controls | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

4. Governance Board

For Enterprise SaaS, VectorCloud Systems Inc. shall establish operational, legal, security, privacy, finance, and compliance reviewers with documented decision rights. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for governance board.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 04 | Area: Governance Board | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

5. Onboarding Gate

For Enterprise SaaS, VectorCloud Systems Inc. shall block production use until risk classification, architecture review, data owner approval, security review, and contract signoff are complete. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for onboarding gate.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 05 | Area: Onboarding Gate | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

6. Service Description

For Enterprise SaaS, VectorCloud Systems Inc. shall state what the provider may do, what it may not do, and which activities need a separate change order. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for service description.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 06 | Area: Service Description | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

7. Customer Responsibilities

For Enterprise SaaS, VectorCloud Systems Inc. shall identify required approvals, access provisioning, data-quality responsibilities, and evidence response timelines. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for customer responsibilities.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 07 | Area: Customer Responsibilities | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

8. Provider Responsibilities

For Enterprise SaaS, VectorCloud Systems Inc. shall require professional care, trained personnel, documented controls, subcontractor oversight, and audit cooperation. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for provider responsibilities.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 08 | Area: Provider Responsibilities | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

9. Regulatory Change

For Enterprise SaaS, VectorCloud Systems Inc. shall require impact assessment, control updates, pricing discussion, and implementation plan when law or regulator guidance changes. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for regulatory change.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 09 | Area: Regulatory Change | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

10. Policies And Standards

For Enterprise SaaS, VectorCloud Systems Inc. shall bind the provider to security, privacy, AI, procurement, continuity, records, and acceptable-use policies supplied by customer. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for policies and standards.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 10 | Area: Policies And Standards | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

11. Personnel And Background Screening

For Enterprise SaaS, VectorCloud Systems Inc. shall require appropriate screening, role-based training, confidentiality obligations, and access removal at exit. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for personnel and background screening.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 11 | Area: Personnel And Background Screening | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

12. Conflicts Of Interest

For Enterprise SaaS, VectorCloud Systems Inc. shall require disclosure of conflicting customers, incentives, related-party arrangements, and independence impairments. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for conflicts of interest.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 12 | Area: Conflicts Of Interest | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

13. Subcontracting

For Enterprise SaaS, VectorCloud Systems Inc. shall require approval for material subcontractors, flow-down clauses, evidence rights, and termination support. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for subcontracting.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 13 | Area: Subcontracting | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

14. Change Control

For Enterprise SaaS, VectorCloud Systems Inc. shall require risk assessment before changing scope, location, subprocessors, integrations, data classes, AI use, or access model. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for change control.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 14 | Area: Change Control | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

15. Fees And Invoicing Controls

For Enterprise SaaS, VectorCloud Systems Inc. shall align billing events to accepted deliverables, usage reports, rate cards, credits, and disputed invoice procedures. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for fees and invoicing controls.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 15 | Area: Fees And Invoicing Controls | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

16. Service Levels

For Enterprise SaaS, VectorCloud Systems Inc. shall define uptime, response, restoration, data delivery, support, reporting, and incident communication measures. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for service levels.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 16 | Area: Service Levels | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

17. Service Credits

For Enterprise SaaS, VectorCloud Systems Inc. shall state credits do not replace corrective actions, regulatory duties, or termination rights for chronic failure. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for service credits.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 17 | Area: Service Credits | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

18. Acceptance Testing

For Enterprise SaaS, VectorCloud Systems Inc. shall require functional, security, privacy, continuity, integration, and reporting tests before production acceptance. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for acceptance testing.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 18 | Area: Acceptance Testing | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

19. Documentation

For Enterprise SaaS, VectorCloud Systems Inc. shall require architecture diagrams, runbooks, integration inventory, data maps, control matrix, and evidence pack maintenance. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for documentation.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 19 | Area: Documentation | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

20. Records Retention

For Enterprise SaaS, VectorCloud Systems Inc. shall preserve approvals, logs, exports, support records, change records, audit evidence, and decision files for defined periods. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for records retention.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 20 | Area: Records Retention | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

21. Audit Rights

For Enterprise SaaS, VectorCloud Systems Inc. shall permit questionnaire, evidence review, independent assurance report, interview, remediation tracking, and targeted audit. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for audit rights.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 21 | Area: Audit Rights | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

22. Incident Management

For Enterprise SaaS, VectorCloud Systems Inc. shall define security, privacy, continuity, physical, export, payment, and data-quality incidents with severity levels. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for incident management.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 22 | Area: Incident Management | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

23. Notification

For Enterprise SaaS, VectorCloud Systems Inc. shall require prompt notices, factual updates, root cause, containment, legal hold, communications approval, and corrective plan. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for notification.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 23 | Area: Notification | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

24. Remediation

For Enterprise SaaS, VectorCloud Systems Inc. shall require tracked corrective actions, owners, deadlines, residual risk acceptance, and executive escalation for overdue blockers. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for remediation.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 24 | Area: Remediation | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

25. Business Continuity

For Enterprise SaaS, VectorCloud Systems Inc. shall require continuity plan, disaster recovery plan, tabletop test, restoration evidence, manual workaround, and dependency mapping. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for business continuity.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 25 | Area: Business Continuity | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

26. Exit Management

For Enterprise SaaS, VectorCloud Systems Inc. shall require transition plan, data export, knowledge transfer, secrets rotation, subcontractor disengagement, and deletion certification. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for exit management.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 26 | Area: Exit Management | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

27. Termination Rights

For Enterprise SaaS, VectorCloud Systems Inc. shall allow termination for uncured breach, security failure, regulatory prohibition, chronic SLA failure, or unresolved approval blocker. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for termination rights.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 27 | Area: Termination Rights | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

28. Liability Allocation

For Enterprise SaaS, VectorCloud Systems Inc. shall separate ordinary commercial liability from confidentiality, data protection, security, fraud, wilful misconduct, and IP claims. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for liability allocation.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 28 | Area: Liability Allocation | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

29. Insurance

For Enterprise SaaS, VectorCloud Systems Inc. shall require technology E&O, cyber, crime, professional liability, transit/warehouse coverage where relevant, and evidence of renewal. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for insurance.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 29 | Area: Insurance | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

30. Confidentiality

For Enterprise SaaS, VectorCloud Systems Inc. shall cover business, technical, pricing, architecture, security, data, model, and investigation information with survival terms. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for confidentiality.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 30 | Area: Confidentiality | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

31. Intellectual Property

For Enterprise SaaS, VectorCloud Systems Inc. shall separate background IP, deliverables, configurations, customer data, trained artifacts, documentation, and feedback. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for intellectual property.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 31 | Area: Intellectual Property | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

32. Open Source And Third-Party Components

For Enterprise SaaS, VectorCloud Systems Inc. shall require inventory, license compliance, vulnerability management, provenance, and replacement rights. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for open source and third-party components.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 32 | Area: Open Source And Third-Party Components | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

33. Publicity Restrictions

For Enterprise SaaS, VectorCloud Systems Inc. shall prohibit public use of customer name, data, logo, case study, benchmark, or regulator discussion without written approval. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for publicity restrictions.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 33 | Area: Publicity Restrictions | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

34. Dispute Escalation

For Enterprise SaaS, VectorCloud Systems Inc. shall require operational escalation, executive escalation, interim performance, evidence preservation, and venue selection. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for dispute escalation.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 34 | Area: Dispute Escalation | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

35. Regulator Cooperation

For Enterprise SaaS, VectorCloud Systems Inc. shall require assistance for supervisory authority inquiries, audits, information requests, breach notifications, and remediation evidence. The obligation applies to workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and to all records concerning tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

- Required evidence: owner, approval date, artifact ID, renewal date, exception status, and reviewer for regulator cooperation.
- Approval blocker: unresolved gaps affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval must remain visible in the risk register until accepted by Customer.

Clause 35 | Area: Regulator Cooperation | Customer: Northstar Retail Holdings | Provider: VectorCloud Systems Inc. | Evidence cadence: onboarding and annual refresh

Schedule B - Security, Privacy, Operational, And Supply-Chain Control Matrix

The following controls are written as test evidence for an enterprise compliance agent. Each row should be parsed as a possible obligation, blocker, owner action, or evidence requirement for Enterprise SaaS.

CTRL-01 Identity And Access

The parties assign identity and access as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering named accounts, MFA, least privilege, joiner-mover-leaver workflow, and quarterly recertification.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-01 | Control: Identity And Access | Evidence: named accounts, MFA, least privilege, joiner-mover-leaver workflow, and quarterly recertification | Blocker if missing: yes for high-risk or regulated processing

CTRL-02 Privileged Access

The parties assign privileged access as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering ticketed elevation, time limits, session recording, command logging, approval evidence, and emergency break-glass review.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-02 | Control: Privileged Access | Evidence: ticketed elevation, time limits, session recording, command logging, approval evidence, and emergency break-glass review | Blocker if missing: yes for high-risk or regulated processing

CTRL-03 Authentication

The parties assign authentication as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering SSO, certificate or key rotation, conditional access, device posture, and credential vaulting.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-03 | Control: Authentication | Evidence: SSO, certificate or key rotation, conditional access, device posture, and credential vaulting | Blocker if missing: yes for high-risk or regulated processing

CTRL-04 Authorization

The parties assign authorization as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering role definitions, segregation of duties, service account ownership, API scope limits, and customer revocation rights.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-04 | Control: Authorization | Evidence: role definitions, segregation of duties, service account ownership, API scope limits, and customer revocation rights | Blocker if missing: yes for high-risk or regulated processing

CTRL-05 Encryption

The parties assign encryption as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering TLS for transit, encryption at rest, key ownership, key rotation, and secure backup encryption.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-05 | Control: Encryption | Evidence: TLS for transit, encryption at rest, key ownership, key rotation, and secure backup encryption | Blocker if missing: yes for high-risk or regulated processing

CTRL-06 Logging

The parties assign logging as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering admin activity, API calls, data exports, model calls, configuration changes, and failed access attempts.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-06 | Control: Logging | Evidence: admin activity, API calls, data exports, model calls, configuration changes, and failed access attempts | Blocker if missing: yes for high-risk or regulated processing

CTRL-07 Monitoring

The parties assign monitoring as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering alert thresholds, SIEM export, anomaly detection, health checks, and operational dashboards.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-07 | Control: Monitoring | Evidence: alert thresholds, SIEM export, anomaly detection, health checks, and operational dashboards | Blocker if missing: yes for high-risk or regulated processing

CTRL-08 Vulnerability Management

The parties assign vulnerability management as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering scanning, severity rules, patch timelines, exception approval, and retest evidence.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-08 | Control: Vulnerability Management | Evidence: scanning, severity rules, patch timelines, exception approval, and retest evidence | Blocker if missing: yes for high-risk or regulated processing

CTRL-09 Secure Development

The parties assign secure development as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering secure SDLC, code review, dependency scanning, branch protection, secrets scanning, and release approval.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-09 | Control: Secure Development | Evidence: secure SDLC, code review, dependency scanning, branch protection, secrets scanning, release approval | Blocker if missing: yes for high-risk or regulated processing

CTRL-10 Penetration Testing

The parties assign penetration testing as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering annual testing, scope approval, remediation evidence, executive summary, and retest letter.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-10 | Control: Penetration Testing | Evidence: annual testing, scope approval, remediation evidence, executive summary, and retest letter | Blocker if missing: yes for high-risk or regulated processing

CTRL-11 Network Security

The parties assign network security as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering segmentation, private connectivity where available, firewall rules, allowlists, and egress control.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-11 | Control: Network Security | Evidence: segmentation, private connectivity where available, firewall rules, allowlists, and egress control | Blocker if missing: yes for high-risk or regulated processing

CTRL-12 Endpoint Security

The parties assign endpoint security as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering managed devices, EDR, disk encryption, patching, removable media restrictions, and lost-device handling.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-12 | Control: Endpoint Security | Evidence: managed devices, EDR, disk encryption, patching, removable media restrictions, and lost device handling | Blocker if missing: yes for high-risk or regulated processing

CTRL-13 Cloud Configuration

The parties assign cloud configuration as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering baseline hardening, configuration drift, infrastructure-as-code review, and tenant isolation verification.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-13 | Control: Cloud Configuration | Evidence: baseline hardening, configuration drift, infrastructure-as-code review, and tenant isolation verification | Blocker if missing: yes for high-risk or regulated processing

CTRL-14 Data Classification

The parties assign data classification as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering classification labels, handling rules, field mapping, retention rules, and data owner signoff.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-14 | Control: Data Classification | Evidence: classification labels, handling rules, field mapping, retention rules, and data owner signoff | Blocker if missing: yes for high-risk or regulated processing

CTRL-15 Data Minimization

The parties assign data minimization as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering purpose limitation, field reduction, sampling controls, masking, and prohibited-data scanning.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-15 | Control: Data Minimization | Evidence: purpose limitation, field reduction, sampling controls, masking, and prohibited-data scanning | Blocker if missing: yes for high-risk or regulated processing

CTRL-16 Data Retention

The parties assign data retention as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering retention schedule, legal hold, deletion queue, backup retirement, and deletion certificate.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-16 | Control: Data Retention | Evidence: retention schedule, legal hold, deletion queue, backup retirement, and deletion certificate | Blocker if missing: yes for high-risk or regulated processing

CTRL-17 Data Transfer

The parties assign data transfer as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering approved locations, transfer safeguards, encryption, access controls, and destination inventory.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-17 | Control: Data Transfer | Evidence: approved locations, transfer safeguards, encryption, access controls, and destination inventory | Blocker if missing: yes for high-risk or regulated processing

CTRL-18 Subprocessor Oversight

The parties assign subprocessor oversight as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering due diligence, flow-down terms, change notice, objection right, and annual review.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-18 | Control: Subprocessor Oversight | Evidence: due diligence, flow-down terms, change notice, objection right, and annual review | Blocker if missing: yes for high-risk or regulated processing

CTRL-19 Incident Response

The parties assign incident response as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering playbooks, severity taxonomy, containment, forensic preservation, and communication approval.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-19 | Control: Incident Response | Evidence: playbooks, severity taxonomy, containment, forensic preservation, and communication approval | Blocker if missing: yes for high-risk or regulated processing

CTRL-20 Continuity

The parties assign continuity as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering RTO/RPO, tabletop test, alternate processing, dependency mapping, and restoration evidence.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-20 | Control: Continuity | Evidence: RTO/RPO, tabletop test, alternate processing, dependency mapping, and restoration evidence | Blocker if missing: yes for high-risk or regulated processing

CTRL-21 Exit

The parties assign exit as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering export format, assistance period, knowledge transfer, data deletion, and transition governance.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-21 | Control: Exit | Evidence: export format, assistance period, knowledge transfer, data deletion, and transition governance | Blocker if missing: yes for high-risk or regulated processing

CTRL-22 Audit Evidence

The parties assign audit evidence as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering control owner, evidence artifact, refresh cadence, reviewer, deficiency handling, and evidence ID.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-22 | Control: Audit Evidence | Evidence: control owner, evidence artifact, refresh cadence, reviewer, deficiency handling, and evidence ID | Blocker if missing: yes for high-risk or regulated processing

CTRL-23 Responsible AI

The parties assign responsible ai as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering intended use, prohibited use, human approval, testing, monitoring, and unsupported certainty controls.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-23 | Control: Responsible AI | Evidence: intended use, prohibited use, human approval, testing, monitoring, and unsupported certainty controls | Blocker if missing: yes for high-risk or regulated processing

CTRL-24 Model Data Use

The parties assign model data use as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering training opt-in, fine-tuning prohibition, prompt/output retention, service improvement controls, and deletion.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-24 | Control: Model Data Use | Evidence: training opt-in, fine-tuning prohibition, prompt/output retention, service improvement controls, and deletion | Blocker if missing: yes for high-risk or regulated processing

CTRL-25 Integration Governance

The parties assign integration governance as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering system owner, data owner, API scopes, field mapping, failure handling, and rollback.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-25 | Control: Integration Governance | Evidence: system owner, data owner, API scopes, field mapping, failure handling, and rollback | Blocker if missing: yes for high-risk or regulated processing

CTRL-26 Financial Controls

The parties assign financial controls as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering approval authority, segregation of duties, payment-change controls, reconciliation, and exception reporting.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-26 | Control: Financial Controls | Evidence: approval authority, segregation of duties, payment-change controls, reconciliation, exception reporting | Blocker if missing: yes for high-risk or regulated processing

CTRL-27 Supplier Risk

The parties assign supplier risk as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering criticality, dependency, concentration risk, ownership, subcontractor risk, and remediation tracking.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-27 | Control: Supplier Risk | Evidence: criticality, dependency, concentration risk, ownership, subcontractor risk, and remediation tracking | Blocker if missing: yes for high-risk or regulated processing

CTRL-28 Physical Security

The parties assign physical security as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering facility access, visitor logs, chain of custody, asset tracking, and environmental controls.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-28 | Control: Physical Security | Evidence: facility access, visitor logs, chain of custody, asset tracking, and environmental controls | Blocker if missing: yes for high-risk or regulated processing

CTRL-29 Export Controls

The parties assign export controls as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering classification, license analysis, sanctions screening, end-use, end-user, re-export, and transfer restrictions.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-29 | Control: Export Controls | Evidence: classification, license analysis, sanctions screening, end-use, end-user, re-export, and transfer restrictions | Blocker if missing: yes for high-risk or regulated processing

CTRL-30 Marketing Consent

The parties assign marketing consent as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering lawful basis, consent source, suppression, audience upload approval, data partner review, and deletion.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

CTRL-30 | Control: Marketing Consent | Evidence: lawful basis, consent source, suppression, audience upload approval, data partner review, and deletion | Blocker if missing: yes for high-risk or regulated processing

Schedule C - Domain-Specific Requirements For Enterprise SaaS

These clauses are intentionally specific to Enterprise SaaS and should trigger specialized reasoning rather than generic vendor-risk handling.

DOM-01 Tenant Isolation

The parties assign tenant isolation as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering logical isolation, tenant-specific keys where available, cross-tenant test evidence, and incident escalation.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

DOM-01 | Control: Tenant Isolation | Evidence: logical isolation, tenant-specific keys where available, cross-tenant test evidence, and incident escalation | Blocker if missing: yes for high-risk or regulated processing

DOM-02 SaaS Configuration

The parties assign saas configuration as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering configuration baseline, admin change approval, feature release notice, and customer-controlled settings.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

DOM-02 | Control: SaaS Configuration | Evidence: configuration baseline, admin change approval, feature release notice, and customer-controlled settings | Blocker if missing: yes for high-risk or regulated processing

DOM-03 AI Summary Controls

The parties assign ai summary controls as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering citation requirement, human review, no automatic approval, prompt retention limits, and model-use disclosure.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.

- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

DOM-03 | Control: AI Summary Controls | Evidence: citation requirement, human review, no automatic approval, prompt retention limits, model-use disclosure | Blocker if missing: yes for high-risk or regulated processing

DOM-04 CRM And ITSM Integrations

The parties assign crm and itsm integrations as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering scoped API roles, webhook signing, retry queue, failure notification, and data reconciliation.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

DOM-04 | Control: CRM And ITSM Integrations | Evidence: scoped API roles, webhook signing, retry queue, failure notification, and data reconciliation | Blocker if missing: yes for high-risk or regulated processing

DOM-05 Usage Reporting

The parties assign usage reporting as a control family for privacy, AI governance, cloud security, business continuity, financial reporting, third-party risk. Provider must operate the control for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries and retain evidence covering user counts, API calls, evidence volume, billing reconciliation, and suspicious activity review.

- Testing procedure: sample the latest production configuration, one recent change, one access approval, one exception, and one renewal artifact.
- Failure mode: if evidence is stale, incomplete, or inconsistent with customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, the control is treated as not operating for approval purposes.

DOM-05 | Control: Usage Reporting | Evidence: user counts, API calls, evidence volume, billing reconciliation, and suspicious activity review | Blocker if missing: yes for high-risk or regulated processing

Schedule D - Operational Runbook And Scenario Tests

Provider shall maintain a runbook for normal operations, failed operations, emergency operations, and exit operations involving tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows.

D.1 Scenario - New Production Launch

If a new production launch occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-01 | Trigger: new production launch | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.2 Scenario - Material Subprocessor Change

If a material subprocessor change occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-02 | Trigger: material subprocessor change | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.3 Scenario - Privileged Support Request

If a privileged support request occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-03 | Trigger: privileged support request | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.4 Scenario - Suspected Data Leakage

If a suspected data leakage occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-04 | Trigger: suspected data leakage | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.5 Scenario - Regional Outage

If a regional outage occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-05 | Trigger: regional outage | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.6 Scenario - Billing Dispute

If a billing dispute occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-06 | Trigger: billing dispute | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.7 Scenario - Regulatory Inquiry

If a regulatory inquiry occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-07 | Trigger: regulatory inquiry | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.8 Scenario - Failed Access Review

If a failed access review occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-08 | Trigger: failed access review | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.9 Scenario - Expired Assurance Report

If a expired assurance report occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-09 | Trigger: expired assurance report | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.10 Scenario - Unapproved Integration

If a unapproved integration occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-10 | Trigger: unapproved integration | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.11 Scenario - Customer Exit

If a customer exit occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-11 | Trigger: customer exit | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.12 Scenario - Security Incident

If a security incident occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-12 | Trigger: security incident | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.13 Scenario - Privacy Incident

If a privacy incident occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-13 | Trigger: privacy incident | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.14 Scenario - Change Rollback

If a change rollback occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-14 | Trigger: change rollback | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.15 Scenario - Evidence Challenge

If a evidence challenge occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-15 | Trigger: evidence challenge | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.16 Scenario - Policy Exception

If a policy exception occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-16 | Trigger: policy exception | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.17 Scenario - Critical Vulnerability

If a critical vulnerability occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-17 | Trigger: critical vulnerability | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.18 Scenario - Unsupported Component

If a unsupported component occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-18 | Trigger: unsupported component | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.19 Scenario - Operator Departure

If a operator departure occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-19 | Trigger: operator departure | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.20 Scenario - Service Level Breach

If a service-level breach occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-20 | Trigger: service-level breach | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.21 Scenario - Data Deletion Request

If a data deletion request occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-21 | Trigger: data deletion request | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.22 Scenario - Audit Sample Failure

If a audit sample failure occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-22 | Trigger: audit sample failure | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.23 Scenario - Dependency Concentration Issue

If a dependency concentration issue occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-23 | Trigger: dependency concentration issue | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.24 Scenario - Cross Border Transfer Review

If a cross-border transfer review occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-24 | Trigger: cross-border transfer review | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

D.25 Scenario - Third Party Destination Review

If a third-party destination review occurs, Provider shall open a tracked record, identify the affected service boundary, assess impact to customer identifiers, employee contacts, purchase orders, supplier due diligence records, support tickets, and transaction metadata, assign owner and deadline, and preserve evidence for audit review.

- Required decision output: continue, pause, remediate, escalate, or exit. The decision must reference current evidence and any gap affecting signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval.

SCN-25 | Trigger: third-party destination review | Evidence: ticket, owner, chronology, impact, control response, closure approval | Reviewer: customer control owner

Schedule F - Evidence Acceptance Matrix

EVID-001 | Artifact: contract approval | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence
EVID-001A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.
EVID-001B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.
EVID-002 | Artifact: risk assessment | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence
EVID-002A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.
EVID-002B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.
EVID-003 | Artifact: data map | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence
EVID-003A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-003B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-004 | Artifact: system architecture | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-004A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-004B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-005 | Artifact: integration inventory | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-005A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-005B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-006 | Artifact: security assurance | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-006A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-006B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-007 | Artifact: access approval | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-007A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-007B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-008 | Artifact: privileged access review | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-008A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-008B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-009 | Artifact: change record | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-009A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-009B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-010 | Artifact: incident playbook | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-010A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-010B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-011 | Artifact: continuity test | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-011A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-011B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-012 | Artifact: exit plan | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-012A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-012B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-013 | Artifact: subcontractor review | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-013A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-013B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-014 | Artifact: retention schedule | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-014A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-014B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-015 | Artifact: deletion certificate | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-015A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-015B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-016 | Artifact: service level report | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-016A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-016B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-017 | Artifact: availability report | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-017A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-017B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-018 | Artifact: support ticket sample | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-018A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-018B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-019 | Artifact: audit log export | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-019A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-019B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-020 | Artifact: training record | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-020A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-020B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-021 | Artifact: policy exception | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-021A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-021B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-022 | Artifact: threat model | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-022A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-022B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-023 | Artifact: vulnerability report | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-023A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-023B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-024 | Artifact: penetration test summary | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-024A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-024B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-025 | Artifact: remediation plan | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-025A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-025B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-026 | Artifact: business owner signoff | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-026A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-026B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-027 | Artifact: legal approval | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-027A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-027B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-028 | Artifact: privacy approval | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-028A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-028B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-029 | Artifact: security approval | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-029A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-029B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

EVID-030 | Artifact: finance approval | Applies to: Enterprise SaaS | Minimum fields: owner, date, source system, reviewer, finding status, renewal cadence

EVID-030A | Acceptance rule: artifact must address tenant configuration, customer evidence records, identity federation, API tokens, and supplier risk workflows and must not contradict the stated scope for workflow automation, supplier analytics, CRM reporting, case management, and AI-assisted summaries.

EVID-030B | Blocking rule: if artifact is absent, expired, unsigned, or limited to a non-production environment, the approval status remains conditional.

Schedule G - Known Gaps And Approval Conditions

As of the synthetic effective date, the following items are intentionally incomplete to test blocker detection: signed DPA, model-training exclusion, continuity plan, subprocessor schedule, production access approval. No production approval may be inferred from partial evidence.

G.1 Open Item - Signed Dpa

The open item 'signed DPA' remains a blocking or conditional approval factor until a named owner supplies final evidence, legal and security review are complete, and the residual risk decision is recorded.

- Agent expectation: classify the gap, map the affected domain, state the missing artifact, and recommend the next owner action.

G.2 Open Item - Model Training Exclusion

The open item 'model-training exclusion' remains a blocking or conditional approval factor until a named owner supplies final evidence, legal and security review are complete, and the residual risk decision is recorded.

- Agent expectation: classify the gap, map the affected domain, state the missing artifact, and recommend the next owner action.

G.3 Open Item - Continuity Plan

The open item 'continuity plan' remains a blocking or conditional approval factor until a named owner supplies final evidence, legal and security review are complete, and the residual risk decision is recorded.

- Agent expectation: classify the gap, map the affected domain, state the missing artifact, and recommend the next owner action.

G.4 Open Item - Subprocessor Schedule

The open item 'subprocessor schedule' remains a blocking or conditional approval factor until a named owner supplies final evidence, legal and security review are complete, and the residual risk decision is recorded.

- Agent expectation: classify the gap, map the affected domain, state the missing artifact, and recommend the next owner action.

G.5 Open Item - Production Access Approval

The open item 'production access approval' remains a blocking or conditional approval factor until a named owner supplies final evidence, legal and security review are complete, and the residual risk decision is recorded.

- Agent expectation: classify the gap, map the affected domain, state the missing artifact, and recommend the next owner action.